

Relatório do Experimento 1 — Baseline Clássico OPIN

Análise comparativa com Schardong et al. (2022)

Luciano Figueiredo Coelho | PPGCC/LabSEC/UFSC

1. Objetivo

O Experimento 1 estabelece o denominador da comparação central desta tese. Com criptografia clássica (PS256/RSA-OAEP) e o fluxo de consentimento OPIN real, este experimento mede quanto o ecossistema custa hoje — em bytes, em tempo e por participante.

2. Comparação Direta com Schardong et al. (2022)

A tabela abaixo cruza as métricas do Experimento 1 com os valores equivalentes de Schardong et al. (2022). O objetivo não é comparar os dois trabalhos diretamente — os protocolos são diferentes por design. O objetivo é mostrar que a metodologia é equivalente e que as diferenças nos valores são explicadas pela complexidade regulatória adicional do OPIN em relação a um fluxo OIDC genérico.

Métrica	Frederico (Schardong et al., 2022)	Esta tese OPIN Experimento 1	Metodologia	Justificativa
Custo total do fluxo em bytes	48.798 bytes (ECDSA/ECDHE, OIDCsize Eq. 3.1)	477.375 bytes (OPINsize, Equação 1 desta tese)	Equivalente	Mesma metodologia: equação analítica que decompõe o custo total do fluxo em componentes criptográficos (handshake + JWT + JWK) e calcula o custo esperado. O Frederico usou a Equação 3.1 com os parâmetros do OIDC genérico, nós usamos a Equação 1 com os parâmetros do OPIN. Estrutura idêntica, contexto diferente. A diferença reflete o número de handshakes mTLS do OPIN (41) versus conexões TLS do OIDC genérico (22) e a natureza do protocolo FAPI — mais participantes, mais tokens de credencial e validações de certificado obrigatórias por norma. Não é comparação direta de protocolos — é evidência da

Métrica	Frederico (Schar dong et al., 2022)	Esta tese OPIN Experimento 1	Metodologia	Justificativa
				complexidade regulatória adicional do OPIN.
Número de conexões/requisições HTTP	22 conexões TLS (NTLS)	37 requisições HTTP; 41 handshakes mTLS distintos	Equivalente	Mesma metodologia: contar o número de conexões/requisições no fluxo como parâmetro N da equação de custo. O Frederico contou conexões TLS (NTLS = 22), nós contamos requisições HTTP (37) e handshakes mTLS distintos (41).
Tamanho do custo de autenticação TLS/mTLS (TLSAuth)	1.563 bytes (ECDSA — handshake + assinatura + certificado do servidor, TLS unilateral)	16.254 bytes (mTLS bilateral: 11.263 bytes handshake + 1.494 bytes certificado do cliente + 1.342 bytes root-ca.pem + 2.155 bytes issuer-ca.pem)	Equivalente	Mesma metodologia: medir o custo de autenticação TLS como parâmetro da equação de custo do fluxo, somando os componentes do handshake. No TLS unilateral do Frederico, apenas o servidor apresenta certificado. No mTLS do OPIN, o cliente também se autentica com certificado próprio, o que adiciona o custo do certificado do cliente e torna o handshake mais custoso. O custo de autenticação mútua é um requisito normativo do OPIN — não um overhead evitável.
Tamanho da assinatura JWT (JWTSig)	Parâmetro JWTSig na equação OI DCsize — valor não explicitado no artigo para o baseline clássico	683 bytes b64url / 512 bytes raw (client assertion e request object, RSA-4096, 10 de 13 JWTs) 342 bytes b64url / 256 bytes raw (SSA, RSA-2048, 1 de 13 JWTs) id_token: JWE, não aplicável diretamente	Equivalente	Mesma metodologia: medir o tamanho da assinatura JWT como parâmetro da equação de custo do fluxo. O fluxo OPIN tem dois emissores com chaves de tamanhos diferentes: client_one usa RSA-4096 (requisito normativo ICP-Brasil para participantes do OPIN) e o emissor da SSA usa RSA-2048. O valor dominante no fluxo é 683 bytes (10 de 13 JWTs).
Tamanho do objeto JWK (chave pública — JWKsizePK)	Parâmetro JWKsizePK na equação OI DCsize	256 bytes (RSA-2048, campo n decodificado de base64url,	Equivalente	Mesma metodologia: medir o tamanho da chave pública como parâmetro da equação. O valor de 256 bytes corresponde à chave pública

Métrica	Frederico (Schardong et al., 2022)	Esta tese OPIN Experimento 1	Metodologia	Justificativa
		consistente nos 6 cenários)		RSA-2048 do JWKS do AS. Nota: o client_one usa RSA-4096 (512 bytes de chave pública), mas o JWKsizePK do fluxo refere-se às chaves publicadas no JWKS do AS para validação de tokens — essas são RSA-2048.
Separação custo TLS vs. custo da aplicação	Feito (Figura 8 e Tabela 5) — número agregado por cenário de latência	Feito — handshake mTLS vs. processamento OPIN separados por conexão individual, com P50/P95 por cenário	Equivalente	Mesma metodologia: separar o custo da camada de transporte criptográfico do custo do protocolo de aplicação. Nossa instrumentação produz um número por conexão individual — o resultado consolidado por cenário é equivalente ao do Frederico.
Latência do fluxo em cenários de rede distintos	5 regiões AWS: 14ms, 30ms, 140ms, 225ms, 320ms	6 cenários via tc (Traffic Control): 0ms, 14ms, 30ms, 140ms, 225ms, 320ms	Equivalente	Mesma metodologia: avaliar o impacto da latência de rede no tempo total do fluxo. Usamos tc com os mesmos valores de latência do Frederico, referenciados nos seus dados de regiões AWS.
Bytes por participante	Não decomposto por serviço	AS 41,4% / PKI-CRL 28,7% / RS 27,4% / Directory 2,5%	Contribuição original — solicitação do orientador	Métrica solicitada explicitamente pelo Prof. Dr. Martín Vigil com motivação operacional: provedores de nuvem cobram por dados enviados, não recebidos. A decomposição por participante permite estimar o impacto financeiro diferencial da migração PQC para cada tipo de instituição no ecossistema OPIN.

3. Equação OPINsize

3.1 O que é e para que serve

Schardong et al. (2022) criaram a Equação 3.1 para calcular o custo total esperado de um fluxo OIDC em bytes, decompondo-o em termos que representam cada tipo de operação criptográfica. Em vez de medir bytes na rede diretamente, a equação usa os tamanhos conhecidos dos artefatos e o

número de vezes que cada operação ocorre no fluxo. Isso permite comparar diferentes algoritmos de forma analítica, antes mesmo de implementá-los.

Esta tese adapta essa mesma metodologia para o fluxo de consentimento OPIN, produzindo a Equação 1. O resultado é o OPINsize — o custo total esperado do fluxo em bytes, calculado com os parâmetros reais medidos no Experimento 1. Quando o Experimento 3 substituir os algoritmos clássicos pelos híbridos PQC, a mesma equação vai calcular o OPINsize híbrido. A razão entre os dois é o overhead da migração.

3.2 No que é equivalente ao Frederico

A Equação 1 desta tese é diretamente equivalente à Equação 3.1 de Schardong et al. (2022) na estrutura e na metodologia. As diferenças são de contexto: o parâmetro N_TLS do Frederico (número de conexões TLS) é substituído por N_mTLS (número de handshakes mTLS distintos), que reflete a autenticação mútua obrigatória do OPIN. O parâmetro TLS_KEX + TLS_Auth do Frederico é substituído por mTLS_handshake_bytes, medido diretamente via countingConn no gateway Go.

3.3 A equação

OPINsize = N_mTLS × mTLS_handshake_bytes + N_JWT × JWT_size + N_JWK × JWK_PK_size

Onde cada parâmetro foi medido empiricamente no Experimento 1:

Parâmetro	Valor (cenário 0ms)	Fonte
N_mTLS — número de handshakes mTLS distintos	41	Logs do gateway mTLS — contagem de conexões TCP distintas estabelecidas durante o fluxo
mTLS_handshake_bytes — tamanho do handshake (P50)	11.263 bytes	Logs do gateway mTLS — bytes brutos contados durante o estabelecimento de cada conexão segura
N_JWT — número de JWTs no fluxo	13	Logs da Conformance Suite — tokens de segurança encontrados nos payloads das requisições e respostas
JWT_size — tamanho médio de JWT	1.160 bytes	Logs da Conformance Suite — tamanho médio dos tokens de segurança capturados
N_JWK — número de chamadas ao endpoint /jwks	2	Logs da Conformance Suite — chamadas ao endpoint de chaves públicas do servidor de autorização
JWK_PK_size — tamanho da chave pública individual	256 bytes	Logs da Conformance Suite — tamanho do campo de chave pública (módulo RSA) decodificado, consistente nos 6 cenários

Aplicando os valores do cenário 0ms (baseline sem latência de rede):

$$\text{OPINsize clássico} = 41 \times 11.263 + 13 \times 1.160 + 2 \times 256 = 461.783 + 15.080 + 512 = 477.375 \text{ bytes}$$

O OPINsize não varia entre os cenários de latência porque a latência afeta o tempo de transmissão dos artefatos, não o seu tamanho. A tabela comparativa entre configurações de algoritmo (clássico, PQC puro e híbrido) será apresentada após a conclusão do Experimento 3.

4. Separação Handshake mTLS versus Processamento OPIN

Quando um participante do OPIN faz uma requisição, o tempo total que ela leva tem duas partes distintas: o tempo gasto para estabelecer a conexão segura (handshake mTLS) e o tempo gasto para o servidor processar a requisição e devolver a resposta (processamento OPIN). Schardong et al. (2022) fizeram essa mesma separação entre o custo do TLS e o custo do protocolo OIDC na Figura 8 e Tabela 5 do artigo.

Para medir essa separação no OPIN, instrumentamos o gateway mTLS para registrar o momento exato em que o handshake começa e termina, e o momento em que o processamento da requisição começa e termina. Com esses quatro timestamps por conexão, conseguimos calcular os dois tempos separadamente para cada requisição do fluxo. A tabela abaixo mostra os resultados consolidados por cenário de latência.

Latência	Handshake mTLS — Média (ms)	Handshake mTLS — P95 (ms)	Processamento OPIN — Média (ms)	Processamento OPIN — P95 (ms)
0ms	24	50	83	190
14ms	45	64	52	180
30ms	74	107	82	299
140ms	221	297	292	1.036
225ms	304	470	470	1.629
320ms	454	656	656	2.301

Quando a rede é rápida (cenário 0ms), o servidor passa mais tempo processando a requisição do que estabelecendo a conexão segura — 83ms de processamento contra 24ms de handshake. Isso significa que, nesse cenário, o protocolo OPIN em si é o gargalo, não a segurança da conexão. Quando a rede é lenta (cenário 320ms), os dois tempos se aproximam — 454ms de handshake e 656ms de processamento. A latência de rede começa a pesar tanto no estabelecimento da conexão quanto no processamento da requisição. Esse equilíbrio vai mudar no Experimento 3. Com o certificado híbrido, o handshake mTLS vai carregar uma segunda assinatura — a ML-DSA-65 — que

é muito maior que a assinatura clássica atual. O handshake vai crescer, e a proporção entre os dois tempos vai se alterar. Medir essa alteração é um dos objetivos do Experimento 3.

5. Tamanho do Handshake mTLS em Bytes (Wire Bytes)

Além do tempo, medimos também o tamanho em bytes de tudo que é trocado durante o estabelecimento da conexão segura — desde o primeiro pacote até a conexão estar pronta para uso. Para isso, adaptamos o gateway mTLS para contar os bytes brutos que passam pela conexão TCP durante essa fase.

Latência	Amostras	Média (bytes)	P50 (bytes)	P95 (bytes)	P99 (bytes)
0ms	59	11.327	11.263	13.976	14.740
14ms	56	11.502	11.235	13.976	14.769
30ms	55	11.495	11.003	13.976	14.777
140ms	56	11.542	11.235	13.976	14.771
225ms	63	11.464	11.003	13.976	14.702
320ms	56	11.524	11.235	13.976	14.769

O resultado é estável entre os cenários de latência, o que era esperado: a latência de rede atrasa os dados, mas não muda o quanto de dados é trocado. Um handshake clássico troca aproximadamente 11.234 bytes independentemente de a rede ser rápida ou lenta. Esse número é o ponto de partida para o Experimento 3. Com o certificado híbrido, cada handshake vai carregar uma segunda assinatura ML-DSA-65 embutida no certificado. O handshake vai crescer, e a comparação entre esse novo valor e os 11.234 bytes do baseline clássico vai mostrar quanto a migração pesa especificamente na camada de conexão.

6. Bytes por Participante

No fluxo de consentimento OPIN, quatro tipos de serviço participam da comunicação: o servidor de autorização (AS), que gerencia o login e emite os tokens de acesso; o servidor de dados (RS), que responde com as informações de seguro; a infraestrutura de certificados (PKI/CRL), que valida a cadeia de confiança dos participantes; e o diretório (Directory), que confirma que o cliente é um participante credenciado do ecossistema.

A tabela abaixo mostra quantos bytes cada um desses serviços movimentou no fluxo, em cada cenário de latência. Essa decomposição foi solicitada pelo Prof. Dr. Martín Vigil com uma motivação

prática: provedores de nuvem cobram por dados enviados, não recebidos. Saber quanto cada serviço movimentado permite estimar o impacto financeiro real da migração PQC para cada tipo de participante do ecossistema.

Participante	0ms	14ms	30ms	140ms	225ms	320ms	% do total (0ms)
AS (Authorization Server)	29.696	29.698	29.696	29.704	29.696	29.698	41,4%
PKI/CRL	20.610	20.614	20.614	20.614	20.613	20.612	28,7%
RS (Resource Server)	19.662	19.662	19.662	19.662	19.662	18.730	27,4%
Directory	1.776	1.776	650	1.776	1.504	1.776	2,5%
Total observado (cliente de teste)	71.744	71.750	70.622	71.756	71.475	70.816	100%

O servidor de autorização responde por 41,4% dos bytes do fluxo, a maior fatia. Isso reflete o volume de tokens, respostas OAuth e metadados de sessão que ele emite em cada consentimento. Para o Experimento 3, essa fatia é a mais relevante: é onde a migração PQC vai ter maior impacto financeiro por consentimento processado.

7. Referências para o Experimento 3

O Experimento 1 estabelece os valores de referência que serão usados como ponto de partida no Experimento 3. Para cada métrica medida hoje com criptografia clássica, o Experimento 3 vai produzir o valor equivalente com o esquema híbrido. A razão entre os dois — híbrido dividido pelo clássico — é o overhead da migração. A tabela abaixo consolida esses valores de referência.

Referência	Valor baseline clássico (Experimento 1)	O que o Experimento 3 vai comparar com este valor
OPINsize (0ms de rede)	477.375 bytes	Quanto o fluxo completo de consentimento vai custar com o esquema híbrido — é a razão entre os dois que responde à pergunta central da tese
Handshake mTLS — P50 (wire bytes)	11.263 bytes	Quanto a conexão segura vai custar com o certificado híbrido, que carregará uma segunda assinatura ML-DSA-65
Latência /token — P50 (0ms de rede)	43ms	Quanto tempo a mais o servidor vai gastar para assinar e verificar com dois algoritmos em vez de um

Referência	Valor baseline clássico (Experimento 1)	O que o Experimento 3 vai comparar com este valor
Bytes do Servidor de Autorização — AS (Authorization Server) (0ms)	29.696 bytes (41,4%)	Quanto o Servidor de Autorização vai movimentar a mais por consentimento após a migração para ML-DSA-65
Bytes do Servidor de Dados — RS (Resource Server) (0ms)	19.662 bytes (27,4%)	Quanto o Servidor de Dados vai movimentar a mais por consentimento com as respostas das APIs assinadas com ML-DSA-65
N_mTLS — número de handshakes por fluxo	41 handshakes	Parâmetro fixo da Equação OPINsize — usado para calcular o OPINsize híbrido
N_JWT — número de JWTs no fluxo	13 JWTs	Parâmetro fixo da Equação OPINsize — usado para calcular o OPINsize híbrido junto com o novo JWTSig
JWTSig — tamanho da assinatura JWT	683 bytes b64url / 512 bytes raw (RSA-4096, PS256 — dominante no fluxo, 10 de 13 JWTs)	Na Equação OPINsize do Experimento 3, este valor será substituído pela assinatura ML-DSA-65 (FIPS 204): 3.293 bytes raw / 4.391 bytes b64url — 6,4 vezes maior que a assinatura PS256 atual
JWK_PK_size	256 bytes (RSA-2048)	Na Equação OPINsize do Experimento 3, este valor será substituído pelo tamanho da chave pública pós-quântica. ML-DSA-65 (FIPS 204) tem chave pública de 1.952 bytes — 7,6 vezes maior. ML-KEM-768 (FIPS 203) tem chave pública de 1.184 bytes — 4,6 vezes maior. Esses valores são definidos pelo padrão NIST e não variam por implementação.

8. Conclusão e Próximos Passos

O Experimento 1 teve dois objetivos simultâneos: estabelecer o denominador da comparação central da tese e demonstrar que a metodologia adotada é equivalente à de Schardong et al. (2022), o artigo-base do desenho experimental.

O primeiro objetivo foi alcançado. Com criptografia clássica e o fluxo de consentimento OPIN real, medimos o custo atual do ecossistema em todas as dimensões relevantes: 477.375 bytes de OPINsize analítico, 41 handshakes mTLS com custo médio de 11.263 bytes cada, latência do endpoint crítico /token com P50 de 43ms, e a distribuição de bytes por participante — com o Servidor de Autorização respondendo por 41,4% do fluxo. Esses valores são o ponto de partida. Tudo que o Experimento 3 produzir será comparado com eles.

O segundo objetivo também foi alcançado. A Equação OPINsize desta tese segue a mesma estrutura da Equação 3.1 de Schardong et al. (2022) — equação analítica que decompõe o custo total do fluxo em parâmetros mensuráveis, permitindo comparar configurações de algoritmo antes de implementá-las. A separação entre custo do handshake mTLS e custo do processamento OPIN replica a separação TLS/OIDC da Figura 8 e Tabela 5 do artigo-base. Os cenários de latência de rede cobrem os mesmos valores que o Frederico mediu nas cinco regiões da AWS.

O que diferencia este trabalho do artigo-base não é a metodologia — é o objeto de estudo. O Frederico mediu um fluxo OIDC genérico com TLS unilateral e 22 conexões. Nós medimos o ecossistema OPIN regulatório, com mTLS bilateral obrigatório por norma, certificados ICP-Brasil, perfil FAPI e cadeia causal normativa própria. O OPINsize de 477.375 bytes versus os 48.798 bytes do OIDC genérico do Frederico não é uma discrepância metodológica — é a quantificação da complexidade regulatória adicional do OPIN. Essa diferença é, em si, uma contribuição original desta tese: nenhum trabalho anterior havia medido o custo criptográfico real de um consentimento OPIN.

Os próximos passos seguem uma sequência deliberada. Antes do Experimento 3, o ecossistema será migrado para algoritmos pós-quânticos: atualização da biblioteca do Servidor de Autorização (jose v2.0.7 para v6.x), upgrade do runtime Node.js (v22 para v24.7.0) e instrumentação do Servidor de Dados com ML-DSA-65 e ML-KEM-768 via BouncyCastle 1.79. Com o ambiente migrado, o Experimento 2 rodará o mesmo fluxo com PQC puro — sem o clássico — para confirmar que a instrumentação está correta e que as métricas são metodologicamente equivalentes às do Experimento 1 antes de avançar. Só então o Experimento 3 rodará o esquema híbrido proposto no SAD: PS256 paralelo a ML-DSA-65 e ML-KEM-768, os dois algoritmos coexistindo simultaneamente como durante um período real de transição. A razão entre os valores do Experimento 3 e os desta seção 7 produzirá o overhead da migração — o número que responde à pergunta de pesquisa RQ5/SO6.